
Sprawozdanie z Laboratorium: Bazy Danych

Paweł Łoćwin

Jun 13, 2026

CONTENTS

1	Rozdział 1: Kontrola i konserwacja	2
1.1	Wprowadzenie	2
1.2	Zarządzanie przestrzenią i mechanizm współbieżności	2
1.3	Optymalizacja i statystyki planisty zapytań	2
1.4	Bezpieczeństwo i rygorystyczna kontrola dostępu	3
1.5	Strategie zabezpieczania przed utratą danych	3
1.6	Podsumowanie	3
2	Badania literaturowe	5
2.1	Sprzęt dla bazy danych	5
2.2	Konfiguracja bazy danych PostgreSQL	5
2.2.1	Wstęp	5
2.2.2	Podstawowe parametry	5
2.2.3	Lokalizacja i struktura katalogów PostgreSQL	5
2.2.4	Środowiska i profile	6
2.2.5	Automatyzacja	6
2.2.6	Przykłady	6
2.2.7	Najlepsze praktyki	7
2.2.8	Podsumowanie	7
2.2.9	Szczegółowe omówienie plików konfiguracyjnych	7
2.2.10	postgresql.conf	7
2.2.11	pg_hba.conf	9
2.2.12	pg_ident.conf	11
2.3	Kontrola i konserwacja	12
2.3.1	Wprowadzenie	12
2.3.2	Zarządzanie przestrzenią i mechanizm współbieżności	12
2.3.3	Optymalizacja i statystyki planisty zapytań	13
2.3.4	Bezpieczeństwo i rygorystyczna kontrola dostępu	13
2.3.5	Strategie zabezpieczania przed utratą danych	13
2.3.6	Podsumowanie	14
2.4	Partycjonowanie danych	14
2.5	Bezpieczeństwo Baz Danych	14
2.5.1	1. Model bezpieczeństwa CIA i ochrona infrastruktury	14
2.5.2	2. Ataki na bazy danych i luki w zabezpieczeniach	15
3	Rozdział 3: Projektowanie Bazy Danych: System Zarządzania Biblioteką	18
3.1	Wybór zagadnienia, opis procesów i danych	18
3.1.1	Wybrane zagadnienie:	18
3.1.2	Opis procesów i więzy integralności:	18
3.1.3	Wykaz gromadzonych danych:	18
3.2	Prototyp CSV	18
3.3	Model Konceptualny (Pojęciowy)	19

3.3.1	Zidentyfikowane encje	19
3.3.2	Zdefiniowane atrybuty/własności	19
3.3.3	Opis związków	19
3.3.4	Identyfikacja encji słabych	19
3.3.5	Schemat w notacji Chena	20
3.4	Model logiczny i proces normalizacji	20
3.4.1	Przebieg procesu normalizacji	20
3.4.2	Ostateczna struktura tabel (3NF)	20
3.4.3	Diagram ERD (Model Logiczny)	21
3.5	Model fizyczny bazy danych	21
3.5.1	Model fizyczny dla środowiska SQLite	21
3.5.2	Model fizyczny dla środowiska PostgreSQL	21
4	Rozdział 4: Implementacja fizyczna i zasilanie bazy danych	22
4.1	Definicja fizyczna bazy danych (Zadanie 1)	22
4.1.1	Skrypt dla środowiska PostgreSQL	22
4.1.2	Skrypt dla środowiska SQLite	22
4.2	Mechanizm zasilania bazy danych (Zadanie 2)	23
4.2.1	Formatyzacja danych (Pliki CSV)	23
4.2.2	Implementacja mechanizmu importu	23
4.3	Podsumowanie	24
5	Rozdział 5: Komunikacja i operacje na danych	25
5.1	Wstęp	25
5.2	Pełna specyfikacja stworzonego API	25
5.2.1	Moduł biblioteka_zapytania	25
	Index	28

Autorzy projektu: Paweł Łoćwin, Paweł Łosowski

Wprowadzenie:

Niniejsza dokumentacja stanowi kompletne sprawozdanie z laboratorium przedmiotu Bazy Danych. Projekt obejmuje całościową analizę procesów związanych z administracją i projektowaniem relacyjnych baz danych.

Dokumentacja została podzielona na pięć głównych sekcji:

1. **Rozdział 1: Kontrola i konserwacja** – Analiza fundamentalnych procesów administracyjnych niezbędnych do utrzymania wysokiej dostępności i wydajności systemu bazodanowego. Obejmuje VACUUM, REINDEX, kopie zapasowe i monitoring.
2. **Rozdział 2: Badania literaturowe** – Przegląd źródeł akademickich i naukowo-technicznych dotyczących baz danych, ich architektury, optymalizacji i bezpieczeństwa.
3. **Rozdział 3: Projektowanie bazy danych** – Praktyczne modelowanie systemu zarządzania bibliotecznym katalogiem wypożyczeń. Sekcja obejmuje analizę wymagań, model konceptualny (notacja E-R) oraz model logiczny.
4. **Rozdział 4: Implementacja fizyczna i zasilanie bazy** – Realizacja fizycznego schematu bazy danych poprzez skrypty DDL, mechanizmy importu danych oraz automatyzacja zasilania bazy.
5. **Rozdział 5: Zapytania do bazy danych** – Zaawansowane funkcje SQL w Python, selekcje, agregacje, złączenia, operatory zbiorowe i podzapytania z pełną dokumentacją Sphinx.

ROZDZIAŁ 1: KONTROLA I KONSERWACJA

Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

1.1 Wprowadzenie

Współczesne systemy relacyjnych baz danych to wysoce skomplikowane środowiska, które wymagają ciągłego i proaktywnego nadzoru, aby zagwarantować wysoką dostępność, niezawodność oraz wydajność. Administracja takimi systemami stanowi złożone zagadnienie wymagające zarówno wiedzy teoretycznej, jak i praktycznego doświadczenia w zarządzaniu infrastrukturą informatyczną.

1.2 Zarządzanie przestrzenią i mechanizm współbieżności

PostgreSQL opiera swoje działanie na zaawansowanej architekturze określonej jako Multi-Version Concurrency Control (MVCC). Technologia ta pozwala na równoległy odczyt i zapis danych bez wzajemnego blokowania się transakcji, co stanowi fundamentalną zaletę w środowiskach wieloużytkownikowych o wysokim natężeniu operacji. Aby zapobiec zjawisku drastycznego puchnięcia tabel oraz degradacji wydajności operacji wejścia i wyjścia, konieczna jest regularna konserwacja na poziomie nośnika danych:

- **VACUUM:** Podstawowy proces konserwacyjny odzyskujący miejsce po martwych krotkach. Oznacza on wolne obszary jako dostępne do ponownego zapisu przez nowe instrukcje, zapobiegając niekontrolowanemu wzrostowi rozmiarów tabel na dysku.
- **VACUUM FULL:** Znacznie bardziej inwazyjna wersja operacji, która fizycznie przebudowuje strukturę całej tabeli i trwale zwraca wolne miejsce do systemu operacyjnego. Operacja ta wymaga jednak zablokowania całej tabeli i powinna być wykonywana w godzinach niskiego obciążenia.
- **AUTOVACUUM:** W nowoczesnych środowiskach produkcyjnych utrzymanie czystości dyskowej powierza się wbudowanemu procesowi pracującemu w tle. Monitoruje on na bieżąco statystyki zmian i automatycznie wyzwała operacje czyszczenia, eliminując potrzebę ręcznej interwencji administratora.

Zaniechanie procesu czyszczenia w systemach o wysokiej rotacji danych może doprowadzić nie tylko do spadku wydajności, ale w skrajnych przypadkach do wyczerpania identyfikatorów transakcji, co prowadzi do całkowitego zamrożenia bazy.

```
-- Przykładowe wymuszenie manualnej konserwacji z analizą statystyk dla tabeli  
VACUUM (VERBOSE, ANALYZE) Wypozyczenia;
```

1.3 Optymalizacja i statystyki planisty zapytań

Kolejnym filarem utrzymania sprawności systemu jest kontrola nad optymalizatorem, zwanym planistą zapytań. Silnik bazy danych przed wykonaniem jakiegokolwiek skomplikowanej kwerendy analizuje dostępne drogi realizacji i wybiera najefektywniejszą z punktu widzenia kosztów obliczeniowych.

Aby planista mógł podejmować optymalne decyzje, musi opierać się na wysoce dokładnych i aktualnych statystykach dotyczących rozkładu danych. Obejmują one między innymi histogramy wartości w kolumnach, liczby odrębnych wartości (distinct count), oraz rozmiary tabel i indeksów.

- Instrukcja **ANALYZE** służy do natychmiastowego odświeżenia tych metadanych. Baza pobiera losową próbkę wierszy i na jej podstawie aktualizuje wewnętrzne tabele systemowe, co pozwala uniknąć błędnych oszacowań planu wykonania.
- Bieżące profilowanie wydajności realizowane jest natomiast przy pomocy instrukcji **EXPLAIN ANALYZE**. Narzędzie to uruchamia zapytanie, po czym zwraca nie tylko wynik, ale również szczegółowy opis planu wykonania wraz z rzeczywistymi czasami i liczbami wierszy na każdym kroku.

```
-- Kontrola planu wykonania zapytania z rzeczywistym pomiarem czasu
EXPLAIN ANALYZE
SELECT c.Imie, c.Nazwisko, k.Tytul
FROM Czytelnicy c
JOIN Wypozyczenia w ON c.ID_Czytelnika = w.ID_Czytelnika
JOIN Ksiazki k ON w.ID_Ksiazki = k.ID_Ksiazki
WHERE w.Data_Zwrotu IS NULL;
```

1.4 Bezpieczeństwo i rygorystyczna kontrola dostępu

Bezpieczeństwo danych stanowi absolutny priorytet każdej administracji systemami informatycznymi. Nowoczesne podejście do ochrony baz danych całkowicie odchodzi od wykorzystywania globalnych kont administratora na rzecz zaawansowanego systemu uprawnień opartego na rolach (RBAC – Role-Based Access Control).

System zabezpieczeń środowiska PostgreSQL pozwala na niezwykle elastyczną gradację uprawnień. Definiuje się dedykowane role systemowe przypisane do konkretnych mikrousług lub modułów aplikacji, z precyzyjnie określonymi prawami dostępu do pojedynczych schematów, tabel, a nawet kolumn.

Kluczowym konceptem jest wdrożenie zasady najmniejszych uprawnień (Principle of Least Privilege). Rola wykorzystywana przez aplikację powinna dysponować prawami pozwalającymi wyłącznie na modyfikację danych niezbędnych do jej funkcjonowania, bez dostępu do danych wrażliwych czy możliwości zmiany struktury bazy.

```
-- Przykład implementacji bezpiecznej polityki kontroli dostępu
CREATE ROLE app_user WITH LOGIN PASSWORD 'TrudneHaslo123';
GRANT CONNECT ON DATABASE biblioteka_db TO app_user;
GRANT USAGE ON SCHEMA public TO app_user;
GRANT SELECT, INSERT ON Wypozyczenia TO app_user;
```

1.5 Strategie zabezpieczania przed utratą danych

Nawet najlepiej zoptymalizowany i zabezpieczony system informatyczny jest narażony na błędy ludzkie lub awarie infrastruktury sprzętowej. Dlatego odpowiednia polityka wykonywania kopii zapasowych stanowi ostateczną linię obrony i jest absolutnie niezbędna dla każdej produkcyjnej instancji bazy danych.

Kopie logiczne polegają na ekstrakcji danych z bazy do postaci czystego skryptu języka SQL lub dedykowanego formatu archiwalnego. Narzędzia realizujące to zadanie gwarantują przenośność danych między platformami i wersjami silnika, jednak proces przywracania jest czasochłonny i może nie przywrócić wszystkich zmian z ostatnich minut przed awarią.

Dlatego w krytycznych środowiskach produkcyjnych stosuje się kopie fizyczne połączone z archiwizacją dzienników wyprzedzających. Dzienniki te rejestrują absolutnie każdą zmianę bajtu na poziomie magazynu, co umożliwia odtworzenie bazy do dowolnego punktu w przeszłości z dokładnością do sekundy.

1.6 Podsumowanie

Prawidłowa kontrola i konserwacja środowiska bazodanowego to wielowymiarowy proces, który nie ma punktu końcowego, lecz trwa przez cały cykl życia oprogramowania. Złożoność nowoczesnych systemów relacyjnych wymaga holistycznego podejścia łączącego automatyzację, monitoring i ciągłe doskonalenie.

Samo zaprojektowanie zgodnego ze sztuką schematu relacyjnego jest zaledwie początkiem pracy. Stabilność aplikacji zależy w równej mierze od rygorystycznego zarządzania fizyczną strukturą danych, optymalizacji wykonywanych operacji oraz wdrażania wielowarstwowych strategii bezpieczeństwa i ochrony przed awarią.

Holistyczne spojrzenie na administrację PostgreSQL, obejmujące zarówno automatyzację procesów porządkujących pamięć, jak i ciągłe monitorowanie planów wykonania zapytań, pozwala na budowanie systemów, które są nie tylko funkcjonalne, ale także odpornie i niezawodne w najbardziej wymagających warunkach produkcyjnych.

BADANIA LITERATUROWE

2.1 Sprzęt dla bazy danych

2.2 Konfiguracja bazy danych PostgreSQL

2.2.1 Wstęp

Rozdział opisuje konfigurację połączenia z bazą danych **PostgreSQL** – dojrzałym, open-source’owym systemem zarządzania relacyjnymi bazami danych (RDBMS), który wyróżnia się pełną zgodnością ze standardem SQL oraz silnym naciskiem na rozszerzalność i niezawodność.

Wymagania:

- dostęp do instancji PostgreSQL,
- zmienne środowiskowe,
- narzędzia projektowe (np. `psql`, `pg_isready`).

2.2.2 Podstawowe parametry

Każde połączenie z PostgreSQL wymaga:

- hosta i portu (domyślnie `localhost` i `5432`),
- nazwy bazy danych,
- użytkownika i hasła.

Dane wrażliwe (np. hasła) przechowuj w **zmiennych środowiskowych** – to oddziela konfigurację od kodu. Pamiętaj: zmienne środowiskowe nie są mechanizmem bezpieczeństwa; w produkcji uzupełnij je o dedykowane zarządzanie sekretami (np. HashiCorp Vault, AWS Secrets Manager).

2.2.3 Lokalizacja i struktura katalogów PostgreSQL

Pliki konfiguracyjne PostgreSQL znajdują się w katalogu danych (PGDATA).

Główne pliki konfiguracyjne:

- `postgresql.conf` – podstawowa konfiguracja serwera (port, pamięć, logi)
- `pg_hba.conf` – kontrola dostępu (kto i skąd może się łączyć)
- `pg_ident.conf` – mapowanie użytkowników systemowych na role PostgreSQL

Domyślne lokalizacje:

Table 1: Domyślne lokalizacje

System	Katalog danych
Linux (RPM/DEB)	<code>/var/lib/pgsql/data/</code> lub <code>/var/lib/postgresql/*/main/</code>
Linux (kompilacja źródłowa)	<code>/usr/local/pgsql/data/</code>
Windows	<code>C:\Program Files\PostgreSQL\<version>\data\</code>
Docker	<code>/var/lib/postgresql/data/</code> (w kontenerze)

Zmiana katalogu danych:

```
# Inicjalizacja nowego katalogu
initdb -D /ścieżka/do/katalogu
```

(continues on next page)

(continued from previous page)

```
# Uruchomienie z niestandardowym PGDATA
pg_ctl -D /ścieżka/do/katalogu start
```

Struktura katalogu danych:

```
$PGDATA/
├── postgresql.conf    # główny plik konfiguracyjny
├── pg_hba.conf        # polityka dostępu
├── pg_ident.conf      # mapowanie tożsamości
├── base/              # rzeczywiste bazy danych
├── global/            # tabele systemowe
├── log/               # logi serwera
└── pg_wal/            # Write-Ahead Log (WAL)
```

Sprawdzenie aktualnej lokalizacji:

```
SHOW data_directory;
SHOW config_file;
SHOW hba_file;
```

2.2.4 Środowiska i profile

Przełączanie środowisk PostgreSQL (dev/test/prod) realizuj przez:

- zmienne środowiskowe (np. PGHOST, PGPORT, PGDATABASE, PGUSER, PGPASSWORD),
- profile konfiguracyjne,
- osobne pliki .env dla każdego środowiska.

2.2.5 Automatyzacja

Zalecenia dla PostgreSQL:

- walidacja konfiguracji przy starcie za pomocą pg_isready,
- skrypty sprawdzające kompletność zmiennych środowiskowych,
- integracja z CI/CD (np. GitHub Actions, GitLab CI).

Dokumentację generuj automatycznie (Sphinx).

2.2.6 Przykłady

PostgreSQL – zmienne środowiskowe (.env)

```
PGHOST=localhost
PGPORT=5432
PGDATABASE=aplikacja
PGUSER=app_user
PGPASSWORD=${DB_PASSWORD}
```

PostgreSQL – URL połączenia

```
DATABASE_URL=postgresql://${PGUSER}:${PGPASSWORD}@${PGHOST}:${PGPORT}/${PGDATABASE}
```

PostgreSQL – sprawdzenie połączenia

```
pg_isready -h ${PGHOST} -p ${PGPORT} -U ${PGUSER} -d ${PGDATABASE}
```

2.2.7 Najlepsze praktyki

1. Nie przechowuj sekretów w repozytorium.
2. Stosuj `.env.example` zamiast rzeczywistych danych.
3. Używaj standardowych zmiennych środowiskowych PostgreSQL (PG*).
4. Waliduj konfigurację przed uruchomieniem (`pg_isready`).
5. W środowiskach produkcyjnych używaj połączeń SSL/TLS (`sslmode=require`).

2.2.8 Podsumowanie

Poprawna konfiguracja połączenia z PostgreSQL zwiększa bezpieczeństwo i przenośność aplikacji między środowiskami. Standardowe zmienne środowiskowe oraz narzędzia takie jak `pg_isready` ułatwiają automatyzację i walidację.

2.2.9 Szczegółowe omówienie plików konfiguracyjnych

Po omówieniu podstawowych wymagań środowiskowych można przejść do szczegółowej konfiguracji PostgreSQL. W kolejnych sekcjach przedstawiono najważniejsze parametry konfiguracyjne dostępne w plikach:

- `postgresql.conf` – konfiguracja działania serwera,
- `pg_hba.conf` – kontrola dostępu do bazy danych,
- `pg_ident.conf` – mapowanie użytkowników systemowych na role PostgreSQL.

2.2.10 `postgresql.conf`

Plik `postgresql.conf` jest głównym plikiem konfiguracyjnym klastra PostgreSQL. Zawiera ustawienia wpływające na działanie serwera, wydajność, bezpieczeństwo, logowanie oraz replikację.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW config_file;
```

Najważniejsze parametry

Połączenia sieciowe

`listen_addresses`

Określa adresy IP, na których PostgreSQL nasłuchuje połączeń.

Najczęstsze wartości:

- `localhost` – tylko połączenia lokalne,
- `*` – wszystkie interfejsy sieciowe,
- lista adresów, np. `'192.168.1.10,localhost'`.

`port`

Port TCP używany przez PostgreSQL.

Domyślna wartość:

```
port = 5432
```

`max_connections`

Maksymalna liczba jednoczesnych połączeń z bazą danych.

Zbyt wysoka wartość może zwiększać zużycie pamięci.

Pamięć i wydajność

`shared_buffers`

Ilość pamięci RAM używanej przez PostgreSQL do buforowania danych.

Typowe wartości:

- 128MB – środowiska testowe,
- 25% pamięci RAM – środowiska produkcyjne.

work_mem

Ilość pamięci wykorzystywanej przez operacje sortowania i zapytania.

Parametr jest przydzielany dla pojedynczej operacji.

maintenance_work_mem

Pamięć używana podczas operacji administracyjnych, np.:

- VACUUM,
- CREATE INDEX,
- ALTER TABLE.

effective_cache_size

Szacowany rozmiar pamięci podręcznej dostępnej dla PostgreSQL.

Parametr pomaga optymalizatorowi zapytań wybierać odpowiednie plany wykonania.

Logowanie**logging_collector**

Włącza zapisywanie logów do plików.

Dostępne wartości:

- on,
- off.

log_directory

Katalog przechowywania logów.

log_filename

Wzorzec nazw plików logów.

Przykład:

```
log_filename = 'postgresql-%Y-%m-%d.log'
```

log_min_duration_statement

Określa minimalny czas wykonania zapytania (w ms), po którym zostanie ono zapisane w logach.

Przykład:

```
log_min_duration_statement = 1000
```

Wartość 1000 oznacza logowanie zapytań trwających dłużej niż 1 sekundę.

Bezpieczeństwo**password_encryption**

Algorytm szyfrowania haseł użytkowników.

Zalecana wartość:

```
password_encryption = scram-sha-256
```

ssl

Włącza obsługę połączeń SSL/TLS.

Dostępne wartości:

- on,
- off.

ssl_cert_file / ssl_key_file

Ścieżki do certyfikatu i klucza prywatnego SSL.

Replikacja i WAL**wal_level**

Określa poziom szczegółowości Write-Ahead Log (WAL).

Dostępne wartości:

- minimal,

- replica,
- logical.

max_wal_size

Maksymalny rozmiar plików WAL przed wykonaniem checkpointu.

archive_mode

Włącza archiwizację WAL.

archive_command

Polecenie wykonywane podczas archiwizacji plików WAL.

Przykładowa konfiguracja

```
listen_addresses = '*'
port = 5432
max_connections = 200

shared_buffers = 1GB
work_mem = 16MB
maintenance_work_mem = 256MB

logging_collector = on
log_directory = 'log'

ssl = on
password_encryption = scram-sha-256

wal_level = replica
max_wal_size = 2GB
```

Weryfikacja konfiguracji

Po zmianie parametrów konfigurację można przeładować bez restartu serwera:

```
SELECT pg_reload_conf();
```

Niektóre parametry wymagają pełnego restartu PostgreSQL.
Aktualne wartości parametrów można sprawdzić poleceniem:

```
SHOW shared_buffers;
SHOW wal_level;
SHOW max_connections;
```

2.2.11 pg_hba.conf

Plik `pg_hba.conf` (Host-Based Authentication) odpowiada za kontrolę dostępu do serwera PostgreSQL.
Definiuje:

- kto może połączyć się z bazą danych,
- z jakiego adresu IP,
- do jakiej bazy danych,
- przy użyciu jakiej metody uwierzytelniania.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW hba_file;
```

Składnia wpisu

Każdy wpis w `pg_hba.conf` ma następującą strukturę:

TYPE	DATABASE	USER	ADDRESS	METHOD
------	----------	------	---------	--------

Znaczenie pól:

TYPE

Typ połączenia.

Dostępne wartości:

- `local` – połączenia lokalne (Unix socket),
- `host` – połączenia TCP/IP,
- `hostssl` – połączenia TCP/IP z SSL,
- `hostnossl` – połączenia TCP/IP bez SSL.

DATABASE

Nazwa bazy danych, do której użytkownik może się połączyć.

Możliwe wartości:

- konkretna nazwa bazy,
- `all` – wszystkie bazy,
- `sameuser` – baza o nazwie zgodnej z użytkownikiem.

USER

Użytkownik lub rola PostgreSQL.

ADDRESS

Adres IP lub zakres sieci w notacji CIDR.

Przykłady:

- `127.0.0.1/32`,
- `192.168.1.0/24`,
- `0.0.0.0/0` – wszystkie adresy.

METHOD

Metoda uwierzytelniania użytkownika.

Najczęściej używane metody uwierzytelniania

trust

Zezwala na połączenie bez uwierzytelniania.

Zalecane wyłącznie w środowiskach testowych.

reject

Odrzuca połączenie.

md5

Uwierzytelnianie przy użyciu hasła MD5.

Metoda starsza i mniej bezpieczna niż SCRAM.

scram-sha-256

Nowoczesna metoda uwierzytelniania oparta na SCRAM.

Zalecana dla nowych instalacji PostgreSQL.

peer

Uwierzytelnianie na podstawie użytkownika systemowego.

Najczęściej używane dla lokalnych połączeń Linux/Unix.

ident

Mapowanie użytkownika systemowego przy użyciu `pg_ident.conf`.

Przykładowa konfiguracja

```
# Połączenia lokalne
local    all                                postgres                                peer
```

(continues on next page)

(continued from previous page)

```
# Połączenia localhost IPv4
host    all                all                127.0.0.1/32      scram-sha-256

# Połączenia localhost IPv6
host    all                all                ::1/128           scram-sha-256

# Sieć lokalna
host    aplikacja          app_user          192.168.1.0/24    scram-sha-256
```

Najlepsze praktyki

1. Używaj `scram-sha-256` zamiast `md5`.
2. Ograniczaj dostęp do konkretnych adresów IP.
3. Nie używaj `trust` w środowiskach produkcyjnych.
4. Stosuj `hostssl` dla połączeń zdalnych.
5. Po zmianie konfiguracji wykonuj reload konfiguracji:

```
SELECT pg_reload_conf();
```

2.2.12 pg_ident.conf

Plik `pg_ident.conf` umożliwia mapowanie użytkowników systemowych na role PostgreSQL.

Najczęściej używany jest razem z metodami uwierzytelniania:

- `peer`,
- `ident`.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW ident_file;
```

Zastosowanie

Mechanizm mapowania pozwala określić, który użytkownik systemowy może zostać powiązany z konkretną rolą PostgreSQL.

Jest to szczególnie przydatne:

- w środowiskach Linux/Unix,
- przy automatyzacji administracyjnej,
- dla lokalnych połączeń bez użycia haseł.

Składnia wpisu

MAPNAME	SYSTEM-USERNAME	PG-USERNAME
---------	-----------------	-------------

Znaczenie pól:

MAPNAME

Nazwa mapowania wykorzystywana w `pg_hba.conf`.

SYSTEM-USERNAME

Użytkownik systemu operacyjnego.

PG-USERNAME

Rola PostgreSQL, na którą użytkownik ma zostać zmapowany.

Przykładowa konfiguracja

```
# MAPNAME      SYSTEM-USERNAME  PG-USERNAME
admin_map      postgres          postgres
admin_map      deploy           db_admin
app_map        appuser          aplikacja
```

Przykład użycia w `pg_hba.conf`:

```
local  all  all  peer map=admin_map
```

W powyższym przykładzie użytkownicy systemowi zdefiniowani w `admin_map` mogą logować się jako odpowiadające im role PostgreSQL.

Najlepsze praktyki

1. Ograniczaj mapowania wyłącznie do wymaganych użytkowników.
2. Nie mapuj użytkowników systemowych na role superuser bez uzasadnienia.
3. Stosuj osobne role administracyjne i aplikacyjne.
4. Dokumentuj wszystkie mapowania użytkowników.
5. Regularnie przeglądaj konfigurację dostępu.

Opracowanie

Autor: Michał Kraus **Przedmiot:** Bazy danych **Data:** maj 2026

2.3 Kontrola i konserwacja

Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

2.3.1 Wprowadzenie

Współczesne systemy relacyjnych baz danych to wysoce skomplikowane środowiska, które wymagają ciągłego i proaktywnego nadzoru, aby zagwarantować wysoką dostępność, niezawodność oraz wydajność. Administracja takimi systemami stanowi złożone zagadnienie wymagające zarówno wiedzy teoretycznej, jak i praktycznego doświadczenia w zarządzaniu infrastrukturą informatyczną.

2.3.2 Zarządzanie przestrzenią i mechanizm współbieżności

PostgreSQL opiera swoje działanie na zaawansowanej architekturze określanej jako Multi-Version Concurrency Control (MVCC). Technologia ta pozwala na równoległy odczyt i zapis danych bez wzajemnego blokowania się transakcji, co stanowi fundamentalną zaletę w środowiskach wieloużytkownikowych o wysokim natężeniu operacji. Aby zapobiec zjawisku drastycznego puchnięcia tabel oraz degradacji wydajności operacji wejścia i wyjścia, konieczna jest regularna konserwacja na poziomie nośnika danych:

- **VACUUM:** Podstawowy proces konserwacyjny odzyskujący miejsce po martwych krotkach. Oznacza on wolne obszary jako dostępne do ponownego zapisu przez nowe instrukcje, zapobiegając niekontrolowanemu wzrostowi rozmiarów tabel na dysku.
- **VACUUM FULL:** Znacznie bardziej inwazyjna wersja operacji, która fizycznie przebudowuje strukturę całej tabeli i trwale zwraca wolne miejsce do systemu operacyjnego. Operacja ta wymaga jednak zablokowania całej tabeli i powinna być wykonywana w godzinach niskiego obciążenia.
- **AUTOVACUUM:** W nowoczesnych środowiskach produkcyjnych utrzymanie czystości dyskowej powierza się wbudowanemu procesowi pracującemu w tle. Monitoruje on na bieżąco statystyki zmian i automatycznie wyzwała operacje czyszczenia, eliminując potrzebę ręcznej interwencji administratora.

Zaniedbanie procesu czyszczenia w systemach o wysokiej rotacji danych może doprowadzić nie tylko do spadku wydajności, ale w skrajnych przypadkach do wyczerpania identyfikatorów transakcji, co prowadzi do całkowitego zamrożenia bazy.

```
-- Przykładowe wymuszenie manualnej konserwacji z analizą statystyk dla tabeli
VACUUM (VERBOSE, ANALYZE) Wypozyczenia;
```

2.3.3 Optymalizacja i statystyki planisty zapytań

Kolejnym filarem utrzymania sprawności systemu jest kontrola nad optymalizatorem, zwanym planistą zapytań. Silnik bazy danych przed wykonaniem jakiegokolwiek skomplikowanej kwerendy analizuje dostępne drogi realizacji i wybiera najefektywniejszą z punktu widzenia kosztów obliczeniowych.

Aby planista mógł podejmować optymalne decyzje, musi opierać się na wysoce dokładnych i aktualnych statystykach dotyczących rozkładu danych. Obejmują one między innymi histogramy wartości w kolumnach, liczby odrębnych wartości (distinct count), oraz rozmiary tabel i indeksów.

- Instrukcja **ANALYZE** służy do natychmiastowego odświeżenia tych metadanych. Baza pobiera losową próbkę wierszy i na jej podstawie aktualizuje wewnętrzne tabele systemowe, co pozwala uniknąć błędnych oszacowań planu wykonania.
- Bieżące profilowanie wydajności realizowane jest natomiast przy pomocy instrukcji **EXPLAIN ANALYZE**. Narzędzie to uruchamia zapytanie, po czym zwraca nie tylko wynik, ale również szczegółowy opis planu wykonania wraz z rzeczywistymi czasami i liczbami wierszy na każdym kroku.

```
-- Kontrola planu wykonania zapytania z rzeczywistym pomiarem czasu
EXPLAIN ANALYZE
SELECT c.Imie, c.Nazwisko, k.Tytul
FROM Czytelnicy c
JOIN Wypozyczenia w ON c.ID_Czytelnika = w.ID_Czytelnika
JOIN Ksiazki k ON w.ID_Ksiazki = k.ID_Ksiazki
WHERE w.Data_Zwrotu IS NULL;
```

2.3.4 Bezpieczeństwo i rygorystyczna kontrola dostępu

Bezpieczeństwo danych stanowi absolutny priorytet każdej administracji systemami informatycznymi. Nowoczesne podejście do ochrony baz danych całkowicie odchodzi od wykorzystywania globalnych kont administratora na rzecz zaawansowanego systemu uprawnień opartego na rolach (RBAC – Role-Based Access Control).

System zabezpieczeń środowiska PostgreSQL pozwala na niezwykle elastyczną gradację uprawnień. Definiuje się dedykowane role systemowe przypisane do konkretnych mikrousług lub modułów aplikacji, z precyzyjnie określonymi prawami dostępu do pojedynczych schematów, tabel, a nawet kolumn.

Kluczowym konceptem jest wdrożenie zasady najmniejszych uprawnień (Principle of Least Privilege). Rola wykorzystywana przez aplikację powinna dysponować prawami pozwalającymi wyłącznie na modyfikację danych niezbędnych do jej funkcjonowania, bez dostępu do danych wrażliwych czy możliwości zmiany struktury bazy.

```
-- Przykład implementacji bezpiecznej polityki kontroli dostępu
CREATE ROLE app_user WITH LOGIN PASSWORD 'TrudneHaslo123';
GRANT CONNECT ON DATABASE biblioteka_db TO app_user;
GRANT USAGE ON SCHEMA public TO app_user;
GRANT SELECT, INSERT ON Wypozyczenia TO app_user;
```

2.3.5 Strategie zabezpieczania przed utratą danych

Nawet najlepiej zoptymalizowany i zabezpieczony system informatyczny jest narażony na błędy ludzkie lub awarie infrastruktury sprzętowej. Dlatego odpowiednia polityka wykonywania kopii zapasowych stanowi ostateczną linię obrony i jest absolutnie niezbędna dla każdej produkcyjnej instancji bazy danych.

Kopie logiczne polegają na ekstrakcji danych z bazy do postaci czystego skryptu języka SQL lub dedykowanego formatu archiwalnego. Narzędzia realizujące to zadanie gwarantują przenośność danych między platformami i wersjami silnika, jednak proces przywracania jest czasochłonny i może nie przywrócić wszystkich zmian z ostatnich minut przed awarią.

Dlatego w krytycznych środowiskach produkcyjnych stosuje się kopie fizyczne połączone z archiwizacją dzienników wyprzedzających. Dzienniki te rejestrują absolutnie każdą zmianę bajtu na poziomie magazynu, co umożliwia odtworzenie bazy do dowolnego punktu w przeszłości z dokładnością do sekundy.

2.3.6 Podsumowanie

Prawidłowa kontrola i konserwacja środowiska bazodanowego to wielowymiarowy proces, który nie ma punktu końcowego, lecz trwa przez cały cykl życia oprogramowania. Złożoność nowoczesnych systemów relacyjnych wymaga holistycznego podejścia łączącego automatyzację, monitoring i ciągłe doskonalenie.

Samo zaprojektowanie zgodnego ze sztuką schematu relacyjnego jest zaledwie początkiem pracy. Stabilność aplikacji zależy w równej mierze od rygorystycznego zarządzania fizyczną strukturą danych, optymalizacji wykonywanych operacji oraz wdrażania wielowarstwowych strategii bezpieczeństwa i ochrony przed awarią.

Holistyczne spojrzenie na administrację PostgreSQL, obejmujące zarówno automatyzację procesów porządkujących pamięć, jak i ciągłe monitorowanie planów wykonania zapytań, pozwala na budowanie systemów, które są nie tylko funkcjonalne, ale także odporne i niezawodne w najbardziej wymagających warunkach produkcyjnych.

Tego typu jakis tekst

2.4 Partycjonowanie danych

2.5 Bezpieczeństwo Baz Danych

Dział 7 przeglądu literaturowego poświęcony architekturze bezpieczeństwa, mechanizmom ochrony oraz analizie podatności w nowoczesnych systemach zarządzania bazami danych.

2.5.1 1. Model bezpieczeństwa CIA i ochrona infrastruktury

Rozważając bezpieczeństwo systemów bazodanowych, należy spojrzeć na problem warstwowo. Najniższą, a zarazem najbardziej fundamentalną warstwą jest ochrona samej infrastruktury sprzętowej i sieciowej, na której operuje silnik bazy danych (DBMS). Zanim przejdziemy do szczegółowych konfiguracji silnika, konieczne jest zdefiniowanie nadrzędnych celów bezpieczeństwa oraz zapewnienie izolacji środowiska uruchomieniowego.

Triada CIA w środowisku bazodanowym

Model **CIA** (ang. *Confidentiality, Integrity, Availability*) to klasyczny paradygmat bezpieczeństwa informacji. W kontekście relacyjnych i nierelacyjnych baz danych każdy z tych elementów realizowany jest przez specyficzne mechanizmy:

- **Poufność (Confidentiality):** Gwarantuje, że dane są dostępne wyłącznie dla autoryzowanych podmiotów. W bazach danych osiąga się to poprzez ścisłą kontrolę dostępu (np. RBAC), szyfrowanie danych w spoczynku (TDE - *Transparent Data Encryption*), maskowanie danych wrażliwych oraz szyfrowanie połączeń sieciowych (TLS).
- **Integralność (Integrity):** Zapewnia spójność i poprawność danych, chroniąc je przed nieautoryzowaną modyfikacją. Silniki bazodanowe realizują ten postulat natywnie poprzez właściwości ACID (szczególnie *Consistency*), więzy integralności (klucze obce, ograniczenia *CHECK*), a z punktu widzenia bezpieczeństwa – poprzez audytowanie DML (Data Manipulation Language) i mechanizmy wykrywania anomalii.
- **Dostępność (Availability):** Oznacza pewność, że system odpowie na żądanie w akceptowalnym czasie. Zagrożeniem dla dostępności są awarie sprzętowe oraz ataki DoS. Obroną na poziomie bazy danych są klastry wysokiej dostępności (HA), replikacja (np. *Master-Slave*, *Multi-Master*), partycjonowanie oraz odpowiednio zaprojektowane mechanizmy Disaster Recovery.

Izolacja sieciowa i architektura chmurowa (VPC)

Nawet najlepiej skonfigurowany system uprawnień bazodanowych traci na znaczeniu, jeśli instancja wystawiona jest bezpośrednio do publicznej sieci Internet. Standardem inżynieryjnym w nowoczesnych wdrożeniach (zarówno on-premise, jak i cloud) jest głęboka separacja sieciowa.

W środowiskach chmurowych (np. AWS, Azure, GCP) bazy danych umieszcza się w dedykowanych chmurach prywatnych (**VPC** - *Virtual Private Cloud*). Dobrą praktyką jest wdrożenie architektury wielowarstwowej:

1. **Warstwa publiczna (Public Subnet):** Zawiera load balancery i serwery webowe (np. Nginx), do których dostęp ma użytkownik końcowy.
2. **Warstwa aplikacji (Private Subnet):** Środowisko uruchomieniowe backendu (np. Node.js, Spring Boot).
3. **Warstwa danych (Database Subnet):** Najgłębiej ukryta podsieć prywatna bez routingu do Internetu (brak *Internet Gateway*). Dostęp do niej ma wyłącznie warstwa aplikacji poprzez ściśle określone reguły *Security Groups* lub *Network ACLs* (dopuszczające ruch tylko na konkretnym porcie, np. 5432 dla PostgreSQL, i tylko ze znanych adresów IP warstwy aplikacyjnej).

Takie podejście drastycznie zmniejsza powierzchnię ataku (ang. *attack surface*), eliminując ryzyko bezpośrednich ataków typu *brute-force* na porty bazy danych z zewnątrz.

Konteneryzacja a bezpieczeństwo bazy

Uruchamianie baz danych w kontenerach (np. Docker, Kubernetes) stało się powszechne, jednak niesie ze sobą specyficzne wektory zagrożeń. Kontenery dzielą jądro (kernel) z systemem hosta, co oznacza, że kompromitacja bazy danych może prowadzić do ucieczki z kontenera (ang. *container breakout*).

Aby zminimalizować to ryzyko, stosuje się następujące praktyki:

- **Brak uprawnień roota:** Procesy DBMS (np. `postgres` lub `mysqld`) nigdy nie powinny działać jako użytkownik `root` wewnątrz kontenera. Standardowe obrazy często wymagają jawnego zdefiniowania dyrektywy `USER` w pliku `Dockerfile`.
- **Ograniczenia zasobów (Cgroups):** Podatność silnika bazy na ataki typu *Denial of Service* można złagodzić na poziomie infrastruktury, nakładając twarde limity na zużycie CPU i pamięci RAM przez dany kontener. Zapobiega to sytuacji, w której przeciążona baza kładzie cały serwer hosta (Resource Exhaustion).
- **Read-Only Root Filesystem:** Kontener bazy danych powinien mieć zamontowany system plików w trybie tylko do odczytu, z wyjątkiem ściśle zdefiniowanych wolumenów (ang. *volumes*) przeznaczonych na pliki danych (np. `/var/lib/postgresql/data`). Uniemożliwia to atakującemu wstrzyknięcie złośliwych skryptów do katalogów systemowych po udanym wykorzystaniu luki aplikacyjnej.

2.5.2 2. Ataki na bazy danych i luki w zabezpieczeniach

Ponieważ bazy danych przechowują najbardziej krytyczne informacje organizacji, stanowią główny cel cyberataków. Według zestawień takich jak OWASP Top 10, podatności związane ze wstrzykiwaniem kodu (Injection) oraz błędną konfiguracją od lat utrzymują się w czołówce zagrożeń. Zrozumienie mechaniki tych ataków jest kluczowe do zaprojektowania skutecznych mechanizmów obronnych w warstwie aplikacyjnej i bazodanowej.

Wstrzykiwanie kodu SQL (SQL Injection)

SQL Injection (SQLi) to podatność polegająca na możliwości modyfikacji zapytania SQL poprzez nieodpowiednio zwalidowane dane wejściowe. Pozwala to atakującemu na wykonanie nieautoryzowanych operacji na bazie danych. Klasyczny przykład podatności (język PHP):

```
$username = $_POST['username'];
$query = "SELECT * FROM users WHERE username = '$username'";
$db->execute($query);
```

Jeśli atakujący jako parametr `username` przekaże ciąg `' OR '1'='1'`, zapytanie przyjmie postać:

```
SELECT * FROM users WHERE username = '' OR '1'='1';
```

Ponieważ warunek `'1'='1'` jest zawsze prawdziwy, silnik bazy danych zwróci wszystkie rekordy z tabeli `users`, omijając mechanizm uwierzytelniania.

Rodzaje ataków SQLi:

1. **In-Band SQLi (Classic):** Atakujący używa tego samego kanału komunikacyjnego do przeprowadzenia ataku i zebrania wyników. Najpopularniejsze to *Error-based SQLi* (wymuszanie błędów silnika w celu wycieku metadanych, np. struktury tabel) oraz *Union-based SQLi* (użycie operatora UNION do dołączenia złośliwych zapytań do oryginalnego).
2. **Inferential (Blind) SQLi:** Występuje, gdy aplikacja nie zwraca komunikatów o błędach ani bezpośrednich wyników zapytań. Atakujący musi wnioskować o strukturze danych na podstawie zachowania aplikacji. * **Boolean-based:** Wysyłanie zapytań warunkowych i obserwowanie, czy strona ładuje się inaczej. * **Time-based:** Zmuszanie bazy do wstrzymania działania (np. funkcjami `pg_sleep()` w PostgreSQL lub `WAITFOR DELAY` w SQL Server), aby potwierdzić obecność podatności.
3. **Out-of-Band SQLi:** Wykorzystywane rzadziej, opiera się na wymuszeniu przez silnik bazy danych żądania HTTP lub DNS do zewnętrznego serwera kontrolowanego przez atakującego.

Mitygacja: Podstawową i najskuteczniejszą metodą obrony przed SQLi jest korzystanie z **zapytań parametryzowanych (Prepared Statements)** lub nowoczesnych systemów ORM (Object-Relational Mapping), które oddzielają składnię zapytań od danych wejściowych.

Ataki NoSQL Injection

Wraz ze wzrostem popularności nierelacyjnych baz danych (np. MongoDB, CouchDB), pojawił się mit o ich całkowitej odporności na wstrzykiwanie kodu. Choć nie używają one tradycyjnego dialektu SQL, aplikacje z nich korzystające nadal mogą być podatne na modyfikację logiki zapytań.

Ataki te często bazują na wstrzykiwaniu operatorów bazy danych do zapytań, które aplikacja interpretuje jako obiekty JSON.

Przykład dla MongoDB: Aplikacja Node.js oczekuje poświadczeń przekazanych w formacie JSON:

```
db.collection('users').find({
  username: req.body.username,
  password: req.body.password
});
```

Atakujący wysyła zmodyfikowany payload z użyciem operatora logicznego `$ne` (Not Equal):

```
{
  "username": {"$ne": null},
  "password": {"$ne": null}
}
```

W rezultacie silnik MongoDB wykonuje zapytanie szukające użytkownika, którego login i hasło *nie są nullem*. Zapytanie zwraca pierwszy pasujący rekord (często administratora), umożliwiając logowanie bez znajomości hasła.

Przepełnienie bufora (Buffer Overflow) w DBMS

Silniki baz danych (np. MySQL, PostgreSQL, Oracle) to skomplikowane aplikacje napisane najczęściej w językach C lub C++, co oznacza, że są potencjalnie narażone na błędy zarządzania pamięcią.

Buffer Overflow w kontekście baz danych występuje, gdy atakujący przesyła nieproporcjonalnie duży ciąg danych do bufora o stałej wielkości (np. w parametrze funkcji wbudowanej, mechanizmie autoryzacyjnym lub procedurze składowanej). Gdy dane wykraczają poza zaalokowany obszar pamięci, mogą nadpisać sąsiadujące obszary, w tym wskaźnik powrotu instrukcji (Instruction Pointer).

Może to prowadzić do: 1. **Awarji silnika bazy danych (Crash)** – przerywając ciągłość działania. 2. **Wykonania dowolnego kodu (RCE - Remote Code Execution)** – uruchomienia shellcode'u na serwerze z uprawnieniami procesu bazy danych, co stanowi bezpośrednie wejście do kompromitacji hosta (powiązane z ryzykiem opisanym w rozdziale o konteneryzacji).

Odmowa Usługi (DoS) na poziomie bazy danych

Ataki Denial of Service na bazy danych różnią się od klasycznych ataków sieciowych. Mają one charakter aplikacyjny i celują w wyczerpanie zasobów sprzętowych serwera (CPU, RAM, I/O) lub limitów samego oprogramowania.

- **Wyczerpanie puli połączeń (Connection Exhaustion):** Każdy DBMS ma zdefiniowany limit maksymalnej liczby jednoczesnych połączeń (np. parametr `max_connections` w PostgreSQL). Atakujący, często wykorzystując luki w warstwie aplikacji, może zainicjować tysiące zawieszonych lub bardzo powolnych sesji bazy, uniemożliwiając logowanie legalnym użytkownikom.
- **Asymetryczne obciążenie (Query-based DoS):** Atakujący wstrzykuje i uruchamia zapytania, które są syntaktycznie poprawne, ale drastycznie nieoptymalne kosztowo. Przykładem może być wymuszenie iloczynu kartezjańskiego (CROSS JOIN) na bardzo dużych tabelach bez odpowiednich indeksów, co może zablokować procesor serwera na kilka minut i doprowadzić do blokady całej aplikacji (Deadlock/Timeouts).

Automatyzacja ataków: Narzędzia audytowe

W procesach testów penetracyjnych baz danych, analitycy bezpieczeństwa korzystają ze zautomatyzowanych frameworków. Najpopularniejszym z nich jest **sqlmap** – potężne narzędzie open-source automatyzujące proces wykrywania podatności SQLi i przejmowania kontroli nad serwerami bazodanowymi.

W typowym scenariuszu audytu, uruchomienie polecenia:

```
sqlmap -u "http://podatna-aplikacja.local/item.php?id=1" --dbs
```

pozwoli narzędziu na wykrycie typu wstrzyknięcia (np. czasowe lub błędowe), zidentyfikowanie używanego silnika DBMS oraz – w razie sukcesu – wyliczenie wszystkich baz danych dostępnych na serwerze (enumeracja instancji).

ROZDZIAŁ 3: PROJEKTOWANIE BAZY DANYCH: SYSTEM ZARZĄDZANIA BIBLIOTEKĄ

Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

3.1 Wybór zagadnienia, opis procesów i danych

3.1.1 Wybrane zagadnienie:

System zarządzania wypożyczeniami w bibliotece. Projekt obejmuje obsługę bazy czytelników, katalogu zbiorów bibliotecznych (z uwzględnieniem autorów i kategorii literackich), a także pełen proces ewidencji wypożyczeń, zwrotów oraz historii operacji każdego użytkownika.

3.1.2 Opis procesów i więzy integralności:

Głównym procesem w systemie jest obieg książki między biblioteką a czytelnikiem.

- **Rejestracja:** Czytelnik zapisuje się do biblioteki, podając swoje dane osobowe oraz adresowe. System automatycznie rejestruje datę zapisu.
- **Katalogowanie:** Książki są kategoryzowane (np. Fantastyka, Kryminał, Literatura faktu) i przypisane do konkretnych autorów. Każdy fizyczny egzemplarz książki posiada swój unikalny identyfikator, co umożliwia śledzenie niezależnie każdego egzemplarza.
- **Wypożyczenia i Zwroty:** Proces wypożyczenia łączy czytelnika z konkretnym egzemplarzem książki w czasie. Rejestrowana jest data wypożyczenia. System zakłada konieczność ewidencji dokładnej daty zwrotu rzeczywistego, co pozwala na analizy przeterminowanych wypożyczeń i wzorców korzystania z kolekcji.
- **Statystyki (Więzy integralności):** Pola takie jak “aktualne wypożyczenia” i “suma wypożyczeń” z pierwotnego prototypu są wartościami wyliczalnymi (pochodnymi) na podstawie historii transakcji i są usuwane ze schematu normalnego.

3.1.3 Wykaz gromadzonych danych:

- **Dane czytelnika:** Imię, Nazwisko, Ulica, Kod pocztowy, Miasto, Data zapisu.
- **Dane książki:** Tytuł, Rok wydania, Dostępność.
- **Dane autora:** Imię, Nazwisko.
- **Dane kategorii:** Nazwa gatunku literackiego.
- **Dane transakcyjne:** Data wypożyczenia, Data zwrotu (rzeczywista).

3.2 Prototyp CSV

Aby zweryfikować kompletność przetwarzanych informacji, przygotowano “płaską” (nieznormalizowaną) reprezentację danych dla operacji wypożyczenia, bazującą na pierwotnych wytycznych.

```
Imie,Nazwisko,Ulica,Kod_Pocztowy,Miasto,Data_Zapisu,Tytul_Ksiazki,Imie_Autora,  
Nazwisko_Autora,Kategoria,Data_Wypozyczenia,Data_Zwrotu  
Jan,Kowalski,Kwiatowa 1,00-001,Warszawa,2024-01-15,Wiedźmin,Andrzej,Sapkowski,
```

(continues on next page)

(continued from previous page)

↪Fantastyka, 2024-03-01, 2024-03-15
 Jan, Kowalski, Kwiatowa 1, 00-001, Warszawa, 2024-01-15, Pan Tadeusz, Adam, Mickiewicz, Poezja,
 ↪2024-03-10,
 Anna, Nowak, Polna 2, 31-444, Kraków, 2023-11-05, Lśnienie, Stephen, King, Horror, 2024-02-20,
 ↪2024-03-05

3.3 Model Konceptualny (Pojęciowy)

Na podstawie analizy procesów i zebranych danych opracowano model pojęciowy, identyfikując obiekty, ich cechy oraz powiązania.

3.3.1 Zidentyfikowane encje

- **Czytelnik** - osoba zapisana do biblioteki.
- **Autor** - twórca dzieła literackiego.
- **Książka** - oferowana pozycja z inwentarza biblioteki.
- **Kategoria** - sekcja grupująca gatunkowo księgozbiór.
- **Wypożyczenie** - zdarzenie potwierdzające fakt wydania książki czytelnikowi.

3.3.2 Zdefiniowane atrybuty/własności

- **Czytelnik:** Imię, Nazwisko, Ulica, Kod pocztowy, Miasto, Data zapisu.
- **Autor:** Imię, Nazwisko.
- **Książka:** Tytuł, Rok wydania.
- **Kategoria:** Nazwa kategorii.
- **Wypożyczenie:** Data wypożyczenia, Data zwrotu.

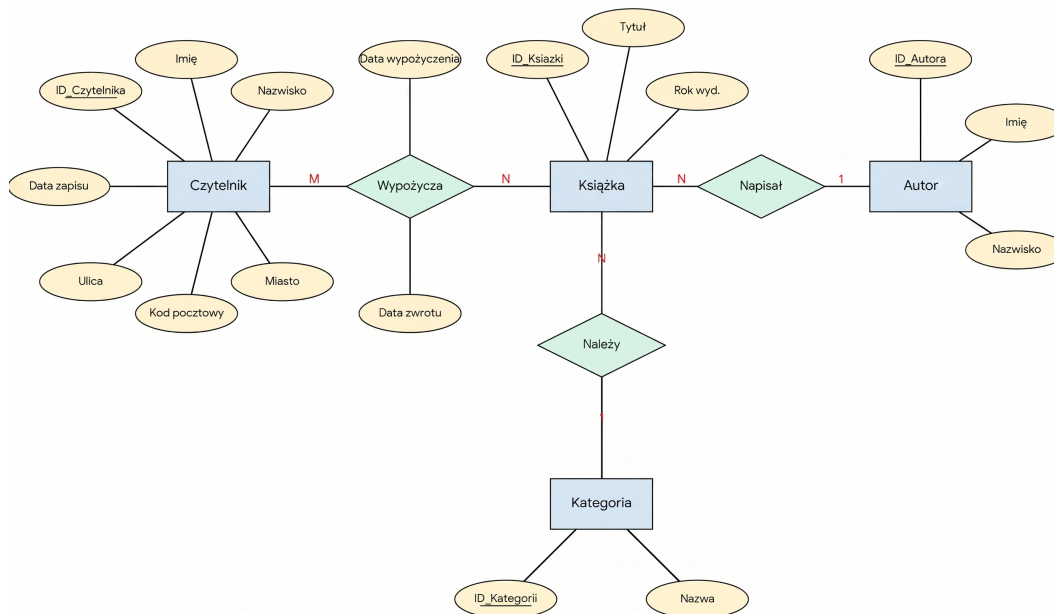
3.3.3 Opis związków

- **Autor – Książka (1:N):** Jeden autor może napisać wiele książek. (Dla uproszczenia modelu zakładamy głównego autora).
- **Kategoria – Książka (1:N):** Kategoria zawiera wiele tytułów.
- **Czytelnik – Wypożyczenie (1:N):** Czytelnik może dokonać wielu wypożyczeń w historii.
- **Książka – Wypożyczenie (1:N):** Jeden egzemplarz książki może być w swojej historii wypożyczany wielokrotnie różnym czytelnikom.

3.3.4 Identyfikacja encji słabych

Występuje relacja wiele-do-wielu (M:N) między Czytelnikiem a Książką (czytelnik czyta wiele książek, książka jest czytana przez wielu czytelników). Związek ten rozwiązywany jest przez encję asocjacyjną **Wypożyczenia**, która przechowuje wszystkie historyczne i bieżące transakcje między dwoma stronami. * **Uzasadnienie:** Byt ten nie istnieje samodzielnie w oderwaniu od konkretnego Czytelnika i konkretnej Książki.

3.3.5 Schemat w notacji Chena



3.4 Model logiczny i proces normalizacji

3.4.1 Przebieg procesu normalizacji

Krok 1: Pierwsza Postać Normalna (1NF) Wiersze są unikalne, tworzymy sztuczne klucze główne (ID_Wypożyczenia). Wartości w komórkach są atomowe. Pojawia się duża redundancja danych adresowych i książkowych.

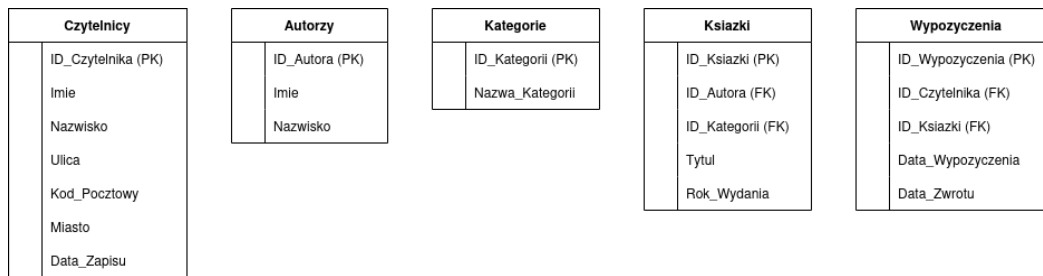
Krok 2: Druga Postać Normalna (2NF) Rozbijamy płaską strukturę względem częściowych zależności. Oddzielamy encje twarde od operacji. Tworzymy bazowe tabele: Czytelnicy oraz Książki. Powstaje tabela Wypożyczenia przechowująca klucze obce ID_Czytelnika oraz ID_Książki, a także daty transakcji. *Uwaga:* Dynamiczne atrybuty takie jak “suma wypożyczeń” z pierwotnego zadania są usuwane ze schematu, ponieważ łamią zasady normalizacji – można je obliczyć zapytaniem SQL typu COUNT(*) na zdarzeniach w tabeli Wypożyczenia.

Krok 3: Trzecia Postać Normalna (3NF) Eliminacja zależności przechodnich. Z tabeli Książki wydzielamy powtarzające się nazwy gatunków do tabeli Kategorie (klucz: ID_Kategorii) oraz dane twórców do tabeli Autorzy (klucz: ID_Autora). Każda tabela reprezentuje teraz niezależną encję o jasno określonym celu biznesowym.

3.4.2 Ostateczna struktura tabel (3NF)

- **Czytelnicy:** ID_Czytelnika (PK), Imię, Nazwisko, Ulica, Kod_Pocztowy, Miasto, Data_Zapisu
- **Autorzy:** ID_Autora (PK), Imię, Nazwisko
- **Kategorie:** ID_Kategorii (PK), Nazwa_Kategorii
- **Książki:** ID_Książki (PK), ID_Autora (FK), ID_Kategorii (FK), Tytuł, Rok_Wydania
- **Wypożyczenia:** ID_Wypożyczenia (PK), ID_Czytelnika (FK), ID_Książki (FK), Data_Wypożyczenia, Data_Zwrotu

3.4.3 Diagram ERD (Model Logiczny)



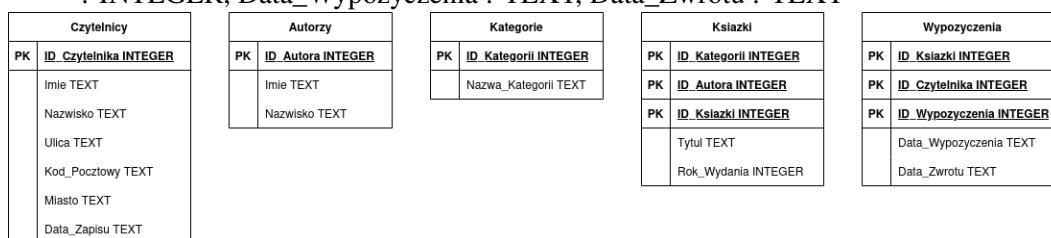
3.5 Model fizyczny bazy danych

Różnice implementacyjne między modelami fizycznymi wynikają wprost z silników RDBMS – ograniczeń typowania SQLite oraz bogatych możliwości deklaracyjnych PostgreSQL.

3.5.1 Model fizyczny dla środowiska SQLite

Z uwagi na okrojony zestaw typów, daty są mapowane jako TEXT.

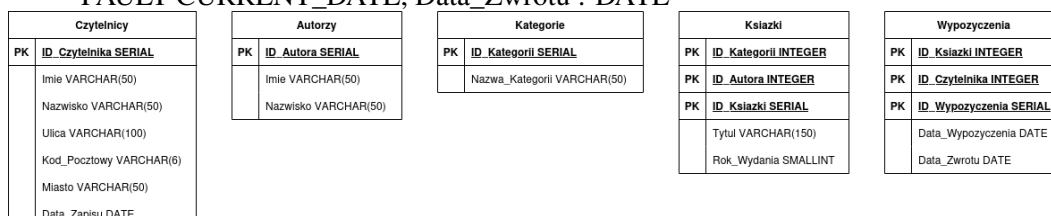
- **Czytelnicy:** ID_Czytelnika : INTEGER PRIMARY KEY, Imie : TEXT, Nazwisko : TEXT, Ulica : TEXT, Kod_Pocztowy : TEXT, Miasto : TEXT, Data_Zapisu : TEXT
- **Autorzy:** ID_Autora : INTEGER PRIMARY KEY, Imie : TEXT, Nazwisko : TEXT
- **Kategorie:** ID_Kategorii : INTEGER PRIMARY KEY, Nazwa_Kategorii : TEXT
- **Książki:** ID_Ksiazki : INTEGER PRIMARY KEY, ID_Autora : INTEGER, ID_Kategorii : INTEGER, Tytul : TEXT, Rok_Wydania : INTEGER
- **Wypożyczenia:** ID_Wypożyczenia : INTEGER PRIMARY KEY, ID_Czytelnika : INTEGER, ID_Ksiazki : INTEGER, Data_Wypożyczenia : TEXT, Data_Zwrotu : TEXT



3.5.2 Model fizyczny dla środowiska PostgreSQL

PostgreSQL umożliwia zastosowanie precyzyjnych i natywnych typów, w tym rygorystycznych typów daty (DATE) oraz optymalizacji pamięciowej dla ciągów znaków (VARCHAR).

- **Czytelnicy:** ID_Czytelnika : SERIAL PRIMARY KEY, Imie : VARCHAR(50), Nazwisko : VARCHAR(50), Ulica : VARCHAR(100), Kod_Pocztowy : VARCHAR(6), Miasto : VARCHAR(50), Data_Zapisu : DATE DEFAULT CURRENT_DATE
- **Autorzy:** ID_Autora : SERIAL PRIMARY KEY, Imie : VARCHAR(50), Nazwisko : VARCHAR(50)
- **Kategorie:** ID_Kategorii : SERIAL PRIMARY KEY, Nazwa_Kategorii : VARCHAR(50)
- **Książki:** ID_Ksiazki : SERIAL PRIMARY KEY, ID_Autora : INTEGER REFERENCES Autorzy, ID_Kategorii : INTEGER REFERENCES Kategorie, Tytul : VARCHAR(150), Rok_Wydania : SMALLINT
- **Wypożyczenia:** ID_Wypożyczenia : SERIAL PRIMARY KEY, ID_Czytelnika : INTEGER REFERENCES Czytelnicy, ID_Ksiazki : INTEGER REFERENCES Książki, Data_Wypożyczenia : DATE DEFAULT CURRENT_DATE, Data_Zwrotu : DATE



ROZDZIAŁ 4: IMPLEMENTACJA FIZYCZNA I ZASILANIE BAZY DANYCH

Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

4.1 Definicja fizyczna bazy danych (Zadanie 1)

Na podstawie opracowanych wcześniej modeli logicznych przygotowano skrypty DDL (Data Definition Language) dla dwóch docelowych silników relacyjnych baz danych: PostgreSQL oraz SQLite. Kody te przygotowały solidną fundamentę dla skutecznego przechowywania i zarządzania danymi biblioteki.

4.1.1 Skrypt dla środowiska PostgreSQL

Środowisko PostgreSQL pozwala na wykorzystanie zaawansowanych, natywnych typów danych oraz rygorystyczne egzekwowanie więzów integralności. W poniższym skrypcie kluczowym elementem jest użycie więzów klucza obcego (FOREIGN KEY) w celu zapewnienia spójności referencyjalnej między tabelami.

```
-- Fragment kodu definicji kluczowych tabel (PostgreSQL)
CREATE TABLE Ksiazki (
    ID_Ksiazki SERIAL PRIMARY KEY,
    ID_Autora INTEGER REFERENCES Autorzy(ID_Autora),
    ID_Kategorii INTEGER REFERENCES Kategorie(ID_Kategorii),
    Tytul VARCHAR(150) NOT NULL,
    Rok_Wydania SMALLINT
);

CREATE TABLE Wypozyczenia (
    ID_Wypozyczenia SERIAL PRIMARY KEY,
    ID_Czytelnika INTEGER REFERENCES Czytelnicy(ID_Czytelnika),
    ID_Ksiazki INTEGER REFERENCES Ksiazki(ID_Ksiazki),
    Data_Wypozyczenia DATE DEFAULT CURRENT_DATE,
    Data_Zwrotu DATE
);
```

4.1.2 Skrypt dla środowiska SQLite

W silniku SQLite struktura ulega pewnemu uproszczeniu z powodu mniejszej rygorystyczności typowania oraz bardzo ograniczonej liczby wbudowanych klas typów danych (np. brak odrębnego typu daty). Pomimo ograniczeń, SQLite pozostaje niezawodnym rozwiązaniem do prototypowania i mniejszych aplikacji.

```
-- Fragment kodu definicji kluczowych tabel (SQLite)
CREATE TABLE Wypozyczenia (
    ID_Wypozyczenia INTEGER PRIMARY KEY AUTOINCREMENT,
    ID_Czytelnika INTEGER,
    ID_Ksiazki INTEGER,
    Data_Wypozyczenia TEXT,
```

(continues on next page)

(continued from previous page)

```
Data_Zwrotu TEXT,
FOREIGN KEY(ID_Czytelnika) REFERENCES Czytelnicy(ID_Czytelnika),
FOREIGN KEY(ID_Ksiazki) REFERENCES Ksiazki(ID_Ksiazki)
);
```

4.2 Mechanizm zasilania bazy danych (Zadanie 2)

Posiadając gotową strukturę bazy, należało wyposażać ją w dane demonstracyjne. Przygotowano zbiór danych testowych, które zostały poddane wsadowemu ładowaniu (batch import).

4.2.1 Formatyzacja danych (Pliki CSV)

Dane do importu przygotowano w niezależnym formacie płaskim CSV (Comma-Separated Values). Takie podejście pozwala na łatwą edycję danych poza systemem bazodanowym. Poniżej zaprezentowano wybrane kategorie książek przygotowane w formacie CSV.

```
Nazwa_Kategorii
Fantastyka
Kryminał
Literatura faktu
Poezja
Horror
```

4.2.2 Implementacja mechanizmu importu

Do zaimportowania powyższych danych wybrano mechanizm wprowadzania wielowartościowego oparty na technice **INSERT (multi-value/batch)**. Rozwiązanie zrealizowano z wykorzystaniem języka Python wraz z biblioteką `psycopg` do komunikacji z bazą PostgreSQL.

Wybór tego mechanizmu podyktowany jest kompromisem między uniwersalnością a wydajnością. Użycie metody `executemany()` na obiekcie kursora bazy danych pozwala na szybkie wstawienie wielu rekordów bez konieczności wykonywania zapytania dla każdego wiersza osobno.

Poniżej przedstawiono fragment skryptu aplikacyjnego odpowiedzialnego za odczyt z pliku i zasilenie tabel:

```
import csv
import psycopg

# 1. Wczytywanie danych z pliku CSV do struktury iterowalnej (listy krotek)
def wczytaj_dane_csv(sciezka_pliku):
    dane = []
    with open(sciezka_pliku, mode='r', encoding='utf-8') as plik:
        csv_reader = csv.reader(plik)
        next(csv_reader) # Pominięcie wiersza nagłówka
        for wiersz in csv_reader:
            dane.append(tuple(wiersz))
    return dane

# 2. Właściwy proces wsadowego importu do bazy PostgreSQL
def importuj_do_postgres(kategorie_do_importu, db_config):
    try:
        # Użycie Context Managera dla bezpiecznego zarządzania transakcjami
        with psycopg.connect(**db_config) as conn:
            with conn.cursor() as cursor:
```

(continues on next page)

(continued from previous page)

```
# Definicja sparametryzowanego zapytania zapobiegającego SQL Injection
zapytanie_sql = "INSERT INTO Kategorie (Nazwa_Kategorii) VALUES (%s)"

# Wsadowe wywołanie zapytań (batch insert)
cursor.executemany(zapytanie_sql, kategorie_do_importu)

print(f"Pomyślnie zaimportowano {len(kategorie_do_importu)} rekordów.
↪")

except Exception as e:
    print(f"Wystąpił błąd operacji wsadowej: {e}")
```

4.3 Podsumowanie

Niniejszy rozdział wieńczy etap projektowania i wdrażania struktury relacyjnej bazy danych dla systemu zarządzania biblioteką. Poprzez transformację modelu logicznego do postaci fizycznej osiągnięto kompletne i funkcjonalne rozwiązanie.

Pierwsza część rozdziału koncentrowała się na **Definicji fizycznej bazy danych (Zadanie 1)**, gdzie dokonano implementacji schematów dla dwóch wiodących silników relacyjnych: PostgreSQL i SQLite, stanowiących praktyczną alternatywę w zależności od wymagań skalowalności oraz zasobów dostępnych w środowisku produkcyjnym. Druga część rozdziału poświęcona została **Mechanizmowi zasilania bazy danych (Zadanie 2)**. Dane demonstracyjne przygotowano w formacie CSV, który zapewnia elastyczność i łatwość edycji zarówno dla administratorów baz danych, jak i dla użytkowników końcowych systemu.

Automatyzacja procesu inicjalizacji systemu za pomocą skryptów Python stanowi znaczący wkład w praktyczność rozwiązania, umożliwiając łatwe replikowanie i testowanie bazy danych w różnych środowiskach bez konieczności wykonywania repetycyjnych czynności manualnych.

Niniejszy projekt stanowi kompletne studium cyklu życia relacyjnej bazy danych – od teoretycznego modelowania (Rozdziały 1-3) poprzez praktyczną implementację (Rozdział 4) – demonstrując całkowity proces od koncepcji do produkcyjnego systemu zarządzania danymi.

ROZDZIAŁ 5: KOMUNIKACJA I OPERACJE NA DANYCH

Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

5.1 Wstęp

Po zdefiniowaniu i zasileniu struktur bazodanowych w poprzednich rozdziałach, system wymaga interfejsu zdolnego do obsługi zaawansowanej logiki biznesowej biblioteki. W tym celu zaimplementowano warstwę dostępu do danych (Data Access Layer) w języku Python.

Wykorzystano techniki tworzenia rozbudowanych zapytań SQL, w tym: * Podzapytania (skorelowane i nieskorelowane w klauzulach SELECT, FROM, WHERE). * Złączenia relacyjne (JOIN, LEFT JOIN). * Analizę agregacyjną (GROUP BY, HAVING). * Operatory teorii mnogości (UNION, INTERSECT, EXCEPT).

5.2 Pełna specyfikacja stworzonego API

Poniżej przedstawiono zautomatyzowaną dokumentację modułu obsługującego połączenia z bazami PostgreSQL oraz SQLite, wygenerowaną na podstawie wbudowanych komentarzy (Docstrings).

5.2.1 Moduł biblioteka_zapytania

Moduł zawiera zestaw zaawansowanych zapytań SQL do obsługi systemu zarządzania biblioteką. Obsługuje dwa silniki bazodanowe: PostgreSQL oraz SQLite.

Wymagania: - psycopg2 (lub psycopg) dla PostgreSQL - sqlite3 (wbudowany) dla SQLite

`biblioteka_zapytania.get_aktywni_czytelnicy_powyzej_limitu(conn, limit_wypozycczen)`

Pobiera listę czytelników, którzy w historii wypożyczyli więcej książek niż wynosi podany limit. Wykorzystuje funkcje agregujące, złączenia oraz klauzulę HAVING.

Parameters

- **conn** (`psycopg2.extensions.connection`) – Obiekt aktywnego połączenia z bazą PostgreSQL (psycopg2).
- **limit_wypozycczen** (`int`) – Minimalna liczba wypożyczeń uprawniająca do znalezienia się na liście.

Returns

Lista krotek zawierająca imię, nazwisko i sumę wypożyczeń czytelnika.

Return type

`list[tuple]`

`biblioteka_zapytania.get_czytelnicy_bez_wypozycczen(conn)`

Pobiera dane czytelników, którzy zapisali się do biblioteki, ale nigdy nie wypożyczyli żadnej książki. Zastosowano tu operator zbiorowy EXCEPT w celu odjęcia zbioru aktywnych od wszystkich.

Parameters

conn (`psycopg2.extensions.connection`) – Obiekt aktywnego połączenia z bazą PostgreSQL.

Returns

Lista krotek z danymi czytelników (ID, Imię, Nazwisko).

Return type

list[tuple]

`biblioteka_zapytania.get_katalog_osob(conn)`

Zwraca ujednoliconą listę wszystkich osób figurujących w systemie, przypisując im odpowiednią rolę. Używa operatora zbiorowego UNION w celu złączenia tabel Czytelnicy i Autorzy.

Parameters

conn (`sqlite3.Connection`) – Obiekt połączenia z bazą SQLite.

Returns

Lista krotek postaci (Imię, Nazwisko, Rola).

Return type

list[tuple]

`biblioteka_zapytania.get_ksiazki_wypozyzione_w_miescie(conn, nazwa_miasta)`

Wyszukuje tytuły książek, które kiedykolwiek zostały wypożyczone przez mieszkańców określonego miasta. Rozwiązanie bazuje na podzapytaniu skorelowanym w klauzuli WHERE.

Parameters

- **conn** (`psycopg2.extensions.connection`) – Obiekt aktywnego połączenia z bazą PostgreSQL.
- **nazwa_miasta** (`str`) – Nazwa miasta do przefiltrowania czytelników.

Returns

Lista krotek zawierająca wyłącznie tytuły książek.

Return type

list[tuple]

`biblioteka_zapytania.get_ksiazki_z_iloscia_wypozyzczen(conn, rok_od)`

Zwraca szczegółowe dane o książkach wydanych po zadanym roku wraz z ilością ich historycznych wypożyczeń. Wykorzystuje funkcje wierszowe (UPPER) oraz podzapytanie w klauzuli SELECT.

Parameters

- **conn** (`psycopg2.extensions.connection`) – Obiekt aktywnego połączenia z bazą PostgreSQL.
- **rok_od** (`int`) – Dolna granica roku wydania książki (wyłącznie).

Returns

Lista krotek (Tytuł, ZWielkiejLitery_NazwiskoAutora, Total_Wypozyzczen).

Return type

list[tuple]

`biblioteka_zapytania.get_najdluzej_przetrzymywane(conn, limit_rekordow)`

Wyszukuje wypożyczenia, które aktualnie trwają (brak daty zwrotu) i sortuje je rosnąco od najstarszych. Wykorzystuje funkcję wierszową DATE() silnika SQLite działającą na ciągach TEXT.

Parameters

- **conn** (`sqlite3.Connection`) – Obiekt połączenia z bazą SQLite.
- **limit_rekordow** (`int`) – Liczba rekordów do zwrócenia (LIMIT).

Returns

Lista krotek (Tytuł, Imię, Nazwisko, Data wypożyczenia).

Return type

list[tuple]

`biblioteka_zapytania.get_puste_kategorie(conn)`

Pobiera nazwy kategorii, do których aktualnie nie przypisano żadnych książek w inwentarzu. Demonstruje wykorzystanie LEFT JOIN w celu znalezienia brakujących relacji (NULL).

Parameters

conn (`sqlite3.Connection`) – Obiekt połączenia z bazą SQLite.

Returns

Lista krotek z nazwami “pustych” kategorii.

Return type

list[tuple]

`biblioteka_zapytania.get_raport_autorow(conn)`

Tworzy zaawansowany raport o autorach, zliczając ich wszystkie książki oraz wskazując tytuł chronologicznie najnowszego dzieła za pomocą podzapytania w SELECT.

Parameters

conn (`sqlite3.Connection`) – Obiekt połączenia z bazą SQLite.

Returns

Lista krotek (Imię autora, Nazwisko, Suma dzieł, Tytuł najnowszej książki).

Return type

list[tuple]

`biblioteka_zapytania.get_srednia_wypozycczen_na_czytelnika(conn)`

Oblicza średnią liczbę wypożyczonych książek przypadającą na jednego aktywnego czytelnika. Wykorzystuje podzapytanie w klauzuli FROM do wcześniejszej agregacji danych.

Parameters

conn (`sqlite3.Connection`) – Obiekt połączenia z bazą SQLite.

Returns

Zwraca jedną krotkę z pojedynczą wartością zmiennoprzecinkową (średnia).

Return type

list[tuple]

`biblioteka_zapytania.get_wszechstronni_czytelnicy(conn)`

Zwraca czytelników (Imię i Nazwisko), którzy wypożyczali książki z kategorii 'Fantastyka' oraz jednocześnie z kategorii 'Kryminał'. Używa operatora zbiorowego INTERSECT.

Parameters

conn (`psycopg2.extensions.connection`) – Obiekt aktywnego połączenia z bazą PostgreSQL.

Returns

Lista krotek z imionami i nazwiskami wszechstronnych czytelników.

Return type

list[tuple]

B

`biblioteka_zapytania`
module, [25](#)

G

`get_aktywni_czytelnicy_powyzej_limitu()` (in module `biblioteka_zapytania`), [25](#)

`get_czytelnicy_bez_wypozycczen()` (in module `biblioteka_zapytania`), [25](#)

`get_katalog_osob()` (in module `biblioteka_zapytania`), [26](#)

`get_ksiazki_wypozyzione_w_miescie()` (in module `biblioteka_zapytania`), [26](#)

`get_ksiazki_z_iloscia_wypozycczen()` (in module `biblioteka_zapytania`), [26](#)

`get_najdluzej_przetrzymywane()` (in module `biblioteka_zapytania`), [26](#)

`get_puste_kategorie()` (in module `biblioteka_zapytania`), [26](#)

`get_raport_autorow()` (in module `biblioteka_zapytania`), [26](#)

`get_srednia_wypozycczen_na_czytelnika()` (in module `biblioteka_zapytania`), [27](#)

`get_wszechstronni_czytelnicy()` (in module `biblioteka_zapytania`), [27](#)

M

module
`biblioteka_zapytania`, [25](#)